

Dokümanın Adı:
Siber Güvenlik Açıklıkları Yönetimi ve İzlenmesi Prosedürü

Gizlilik Derecesi: Tüm Kullanıcılar	Doküman No: BTD.PR11	İlk Yayın Tarihi 25.07.2023	Revizyon Tarihi 25.07.2023	Revizyon No: 0	Sayfa Sayısı: 1/7
--	---------------------------------------	--	---	---------------------------------	------------------------------------

REVİZYON TARİHÇESİ

Revizyon No	Revizyon Tarihi	Açıklama
0	25.07.2023	

Hazırlayan: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI	Süreç Sahibi: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	EYS Onayı ENTEGRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	Kontrol HUKUK MÜŞAVİRLİĞİ HUKUK MÜŞAVİRLİĞİ İ. HUKUK MÜŞAVİRİ	Onaylayan / İdari GENEL MÜDÜR
--	---	---	---	---

Doküman No
BTD.PR11.0

25.07.2023

1. AMAÇ

Bu prosedür siber güvenlik açıklıklarının yönetimini, izlenmesini, verilerin kaybını, değiştirilmesini, kötüye kullanımını ve sızmasını önlemek için alınacak tedbirleri tanımlamak amacıyla hazırlanmıştır.

2. KAPSAM

Bu prosedürde tariflenen uygulama talimatları Posta ve Telgraf Teşkilatı Anonim Şirketi bünyesinde ve dış kaynak kullanılarak geliştirilen uygulamalar için esastır.

3. DAYANAK

Bu prosedür, ISO 27001 Bilgi Güvenliği Yönetim Sistemi Standardının Ek-A 12.6.1 Teknik Açıklıkların Yönetimi maddelerine dayanılarak hazırlanmıştır.

4. TANIMLAR VE KISALTMALAR

4.1 BGOM: Bilgi Güvenliği Operasyon Müdürlüğüdür.

4.2 BGYS: Bilgi Güvenliği Yönetim Sistemidir.

4.3 BT Bilgi Güvenliği Kurulu: 3 (üç) ayda bir Bilgi Teknolojileri Daire Başkanlığı Teknik Müdürlerin katılımı ile toplanan Bilgi Güvenliği Yönetim Sistemi'nin işleyişini değerlendiren kurulu ifade eder.

4.4 BTK: Bilgi Teknolojileri ve İletişim Kurumudur.

4.5 DOS (Disk Operating System): Bilgisayarlar için ufak ve basit bir işletim sistemi türü olup, ana görevi disket ve sabit disk gibi saklama ortamlarının yönetimidir.

4.6 DDOS (Denial-of-service attack): Dağıtık Hizmet Reddi Saldırılarıdır.

4.7 EBYS: Elektronik Belge Yönetim Sistemidir.

4.8 İntranet: PTT AŞ'nin kendi iç ağıdır.

4.9 LFi: Dosya Yükleme Enjeksiyon Saldırısıdır.

4.10 Log: Meydana gelen olayların ve hareketlerin kayıtlarıdır.

4.11 Maddi İşlem Kaydı: Bilişim sistemleri üzerinde yürütülen maddi işlemlerle ilgili kayıtlarıdır.

4.12 PTT AŞ/ Şirket: Posta ve Telgraf Teşkilatı Anonim Şirkettir.

4.13 Siber Güvenlik: Bilgi ile etkileşimi olan uygulama, sistem, network vb. varlıkların güvenliğinin sağlanması için alınması gereken tedbirleridir.

4.14 Siber Olay: Kritik altyapı ve bilgi işlem birimlerindeki bilginin gizlilik, bütünlük veya erişilebilirliğinin ihlal edilmesidir.

4.15 Siber Olaylara Müdahale Ekibi (SOME): PTT AŞ'de bulunan siber güvenlik risklerini azaltan ve siber olay meydana geldiğinde görev tanımında yer alan çalışmaları yapan personelidir.

4.16 SIEM (Security Information and Event Management): Güvenlik Bilgileri ve Olay Yönetimi olarak çevrilir.

4.17 SOME Koordinatörü (Yöneticisi): Bilgi Güvenliği Operasyon Müdürüdür.

4.18 SQLi: SQL Enjeksiyon Saldırısıdır.

4.19 USOM (Ulusal Siber Olaylara Müdahale Merkezi): Yurtiçi ve yurtdışı kaynaklı Siber Olayları tespit ve önleme faaliyetleri yürüten BTK bünyesinde kurulan kuruluştur.

4.20 XSSi: Cross-site (Siteler Arası) Enjeksiyon Saldırısıdır.

5. SORUMLULUKLAR

Bilgi Teknolojileri Altyapı Daire Başkanlığı Teknik Müdürlükleri, Bilişim Daire Başkanlığı Teknik Müdürlükleri, BGYS kapsamındaki diğer daireler ve sistemlerimize ve donanımımıza kalıcı veya geçici erişimi olan herkes tüm faaliyetlerin güvenlik hedefleri ile tutarlılığından sorumludur ve BTD.PR11 Siber Güvenlik Açıklıklarının Yönetimi ve İzlenmesi Süreci Prosedürü'ne uygun hareket etmekle yükümlüdür.

6. UYGULAMA

6.1.1 Güvenlik Tarama

6.1.1 Dışarıdan Hizmet Alımı ile Güvenlik Açıklığı Tarama

6.1.1.1 İnternet ve İntranet Bilgi İşlem sistemlerinin daha güvenli hale getirilmesi için güvenlik denetim hizmetlerinin yerine getirilmesi, çalışmalar neticesinde ortaya çıkacak olası zafiyet, risk ve çözüm önerilerinin raporlanması ve aksiyon alınarak kapatılması gerekmektedir. Dışarıdan hizmet alımı ile sürekli gelişmekte olan saldırı yöntemlerine ve kurumun intranet sistemine eklenen yeni donanımların, kullanıcıların ve yazılımların oluşturabileceği açıklara karşı önlem alınması, bu sayede olası açıkların neden olabileceği daha büyük sorunların önüne geçilmesi amaçlanmaktadır. KVKK, Cumhurbaşkanlığı Dijital Dönüşüm Ofisi gibi bazı regülasyonlar gereği dışarıdan hizmet alımı yöntemi ile yılda bir kez (aşağıda belirtilmiş) genel açıklık taraması ve doğrulaması yapılır.

- a) İnternet Güvenlik Test Hizmeti
- b) Web Uygulama Güvenlik Test Hizmeti
- c) Web Servis API Güvenlik Test Hizmeti
- ç) Yerel Ağ Güvenlik Test Hizmeti
- d) Kablosuz Ağ Güvenlik Test Hizmeti
- e) Dağıtık Hizmet Dışı Bırakma (DDOS) Test Hizmeti
- f) Sosyal Mühendislik Test Hizmeti
- g) Mobil Uygulama Test Hizmeti
- ğ) Zararlı Trafik Analiz Hizmeti (yapmayı istemiyorlar)
- h) Dns Servisleri Güvenlik Test Hizmeti
- ı) Etki alanı ve Kullanıcı Bilgisayarları Güvenlik Test Hizmeti

6.1.1.2 Yukarıda bahsi geçen testlerde, PTT AŞ'nin güvenlik uygulamaların ve sistemlerinin güvenlik açıklıkları ve bunların yarattığı riskler tespit edilir.

6.1.1.3 Ayrıca, Sosyal mühendislik testleri ile kurum içi personelin yetkinlik ve farkındalık seviyeleri en az yılda 1 (bir) kez ölçümlenir. Ortalama saldırılarına karşı farkındalığı olmayan personellere Entegre Yönetim Sistemi Daire Başkanlığı tarafından farkındalık eğitimi verilir.

6.1.1.4 Güvenlik Denetimi, uygulama sunucularında yapılacak servis dışı bırakma (DoS) ve dağıtık servis dışı bırakma (DDoS) saldırıları ile sistemlerin söz konusu saldırılara karşı durumu tespitini içerir.

6.1.1.5 Her bir güvenlik denetimini takiben yüklenici firma Güvenlik Denetimi Raporu hazırlar ve PTT AŞ'ye sunar. Güvenlik Denetim Raporunda sistemde tespit edilen güvenlik açıkları, bunların taşıdıkları riskler itibarıyla öncelikleri ve giderilmesi için yapılması gereken işlemler detaylı ve anlaşılır bir şekilde tarif edilir.

6.1.1.6 Güvenlik Denetimi Raporlarının sunulmasına müteakip güvenlik açıkları için sorumlusu birime Tablo 1'de yer alan süreler içerisinde EBYS üzerinden iletilir. İlgili birim tarafından giderildiği zaman, yüklenici firma bu açıkların giderilip giderilemediğini doğrulama testi ile kontrol eder.

6.1.2 Belirlenen Periyoda Göre Tarama İşlemi

6.1.2.1 PTT AŞ bünyesindeki mevcut kritik varlıkların (Uygulama, Donanım, İşletim Sistemi, vb.) en az yılda 1 (bir) kez tarama işlemine tabi tutularak güncel açıklıklara karşı durumlarının tedbir alınarak iyileştirilmesi amaçlanmaktadır. Buna göre;

6.1.2.2 Mevcut kritik varlıklar tespit edildikten sonra sınıflandırma yapılır, IP adresleri uygulama, veri tabanı ve web sunucusu olarak ayrıca alt sınıflandırmaya tabi tutulur.

6.1.2.3 Sınıflandırma işlemi yapıldıktan sonra varlıklar, BTB.TB07 Güvenlik Tarama Periyot Tablosu'na tarama periyotları ile beraber işlenir ve bu çizelge güncellenir.

6.1.2.4 Tarama periyodu mevcut web uygulamaları için en geç 4 (dört) ayda bir, uygulama veya veri tabanı sunucusu için en geç 6 (altı) ayda bir yapılır. Mobil uygulamalar için detaylı sızma testi manuel olarak yapılabilir.

6.1.2.5 Çizelgedeki periyoda göre IP adresi, web uygulamaları ise otomatize toollar ve SQLi, XSSi, LFi vb. teknikler ile uygulama veya veri tabanı sunucusu ise uygun toollar ve diğer teknikler ile tarama işlemine tabi tutulur.

6.1.2.6 Tarama sonuçları açıklığın ismi, uygulama sahibi, zafiyet seviyesi, faaliyet sorumlusu, IP/URL adresi, port bilgisi, açıklaması, çözüm önerisi ve varsa yararlanılabilecek linkler belirtilerek BTB.TB04 Güvenlik Zafiyet Takip Tablosu'na veya Zafiyet Yönetim Sistemi'ne işlenir.

6.1.3 Talep Üzerine Tarama İşlemi

6.1.3.1 PTT AŞ bünyesindeki yeni oluşturulan/değişiklik yapılan varlıkların üretim ortamına (gerçek ortama) aktarılmadan önce tarama işlemine tabi tutularak güncel açıklıklara karşı durumlarının tedbir alınarak iyileştirilmesi amaçlanmaktadır. Bu taramanın yaptırılmasından ve zafiyetin giderilmesinden başta işletme birimi, sonrasında teknik birim sorumlu. Buna göre;

6.1.3.2 Yeni sunucu kurulduktan sonra servis masası yazılımı üzerinden gelen talep ile sınıflandırmaya tabi tutulur. Ayrıca yeni uygulama devreye alma ve uygulamada yapılan majör değişiklikler sonucunda güvenlik açıklıklarının tespiti amacıyla servis masası yazılımı üzerinden uygulamanın sahibi işletme birimi tarafından açılan tarama Bilgi Güvenliği Operasyon Müdürlüğüne iletilir. Tarama talebi açılırken ilgili birim, ne tür bir tarama olacağı, sorumlu personel, iletişim (e-posta, telefon) bilgileri girilir.

6.1.3.3 Sınıflandırma işlemi yapıldıktan sonra mevcut IP adresi, otomatize toollar ve SQLi, XSSi, LFi vb. teknikler ile uygulama veya veri tabanı sunucusu ise uygun toollar ve diğer teknikler ile tarama işlemine tabi tutulur.

6.1.3.4 Tarama sonuçları açıklığın ismi, etkisi, açıklaması, çözüm önerisi ve varsa yararlanılabilecek linkler belirtilerek BTB.TB04 Güvenlik Zafiyet Tablosu'na işlenir.

6.1.4 Tarama İşlemi Sonucu Raporlama ve Raporun İlgili Birimlere İletilmesi

BTB.TB04 Güvenlik Zafiyet Takip Tablosu veya Zafiyet Yönetim Sistemi'ne işlenen zafiyetler talepte bulunan birime veya sorumlu personeline atanır. Zafiyetlerin atanması sonrasında ilgili sorumlu birime veya personele eposta veya EBYS üzerinden bildirilir.

6.1.5 Açıklıkların Kapatılması ve Kontrol Taramasının Yapılması

Zafiyet Seviyesi	Bildirilme Süresi	Kurumun dışarıya açık sistemlerinde zafiyetin giderilme süresi	Kurum içi sistemlerde zafiyetin giderilme süresi
Çok Yüksek	Max. 1 saat	Maksimum 2 Saat	Maksimum 4 Saat
Yüksek	Max. 1 gün	Maksimum 3 Gün	Maksimum 10 Gün
Orta	Max 3 gün	Maksimum 10 Gün	Maksimum 30 Gün
Düşük	Max 1 hafta	Zafiyetin etkisi risk analizi yapılarak değerlendirilir, maksimum 60 gün içinde güncellenmesi gerekir.	Zafiyetin etkisi risk analizi yapılarak değerlendirilir, maksimum 90 gün içinde güncellenmesi gerekir.
	Max 1 hafta	Uygulamalar ve Açık Kaynak Kodlu Sistemler yama yönetimi, maksimum 30- 60 gün içinde güncellenmesi gerekir.	

Tablo 1 Zafiyet Seviyesine Göre Açıklıkların Kapatılması Tablosu

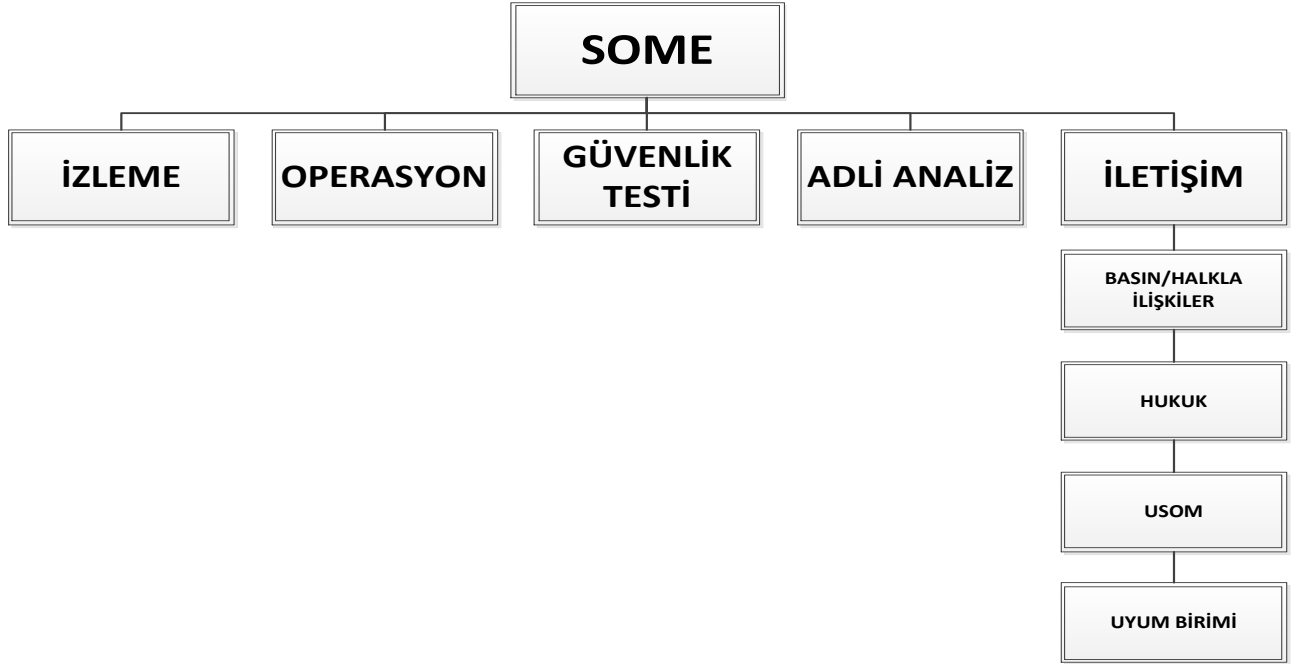
6.1.5.1 Zafiyet seviyeleri Ulusal Güvenlik Açığı Veri Tabanında (National Vulnerability Database) belirlenen cvss kodları ve metrikleri hesaplanılarak belirlenir.

6.1.5.2 Açıklıkların kapatıldığıının bildirilmesi sonrasında, testi yapan firma veya SOME tarafından kontrol taraması yapılır, eğer giderilmemiş açıklık varsa ilgili birime bildirim yapılır. Açıklıklar herhangi bir nedenden dolayı giderilemiyorsa üst yönetime bildirilir. Veri sızıntısı olması durumunda veri sızıntısının etkisi ilgili birimler ve üst yönetim tarafından değerlendirilerek ilgili yerlere bildirilmesi sağlanır. Üst yönetimin talimatları doğrultusunda regülasyonlar kapsamında bildirimde bulunulacak kurumlara Risk ve Uyum Birimi tarafından bildirilir. Basın açıklaması ve sosyal medya bildirimleri Tanıtım ve Medya İlişkileri Daire Başkanlığı tarafından yapılır.

6.1.5.3 Sorumlu birim, EYS.FR24 Risk Bilgilendirme Formu doldurur ve konuya ilişkin, ilgili yerlere yapılan bilgilendirme yazısı ve varsa cevabı ile birlikte varsa Zafiyet Yönetim Sistemi'ne girer yoksa EBYS üzerinden yazı ile Bilgi Teknolojileri Daire Başkanlığına iletir. Açıklıklar kapatıldıktan sonra BT.D.TB04 Güvenlik Zafiyet Takip Tablosu'na veya varsa Zafiyet Yönetim Sistemi'ne "Giderildi" açıklık kapatılamadıysa "Giderilemedi" şeklinde işlenerek kaydedilir.

6.2 Siber Olaylara Müdahale

SOME Organizasyon Şeması aşağıda belirtilmiştir. Bu şemada yer alan birimlerde görevli personel ise BT.D.FR42 Siber Olaylara Müdahale Ekibi Formu'nda belirtilmiştir.



6.2.1 Siber Olay Öncesi SOME'lerin Görev ve Sorumlulukları

6.2.1.1 Şirkette bir Siber Olay olmadan önce SOME birimi, Siber Olay ile ilgili farkındalık çalışmalarını yaparlar. Sistem zafiyetlerini tespit amacıyla penetrasyon testlerinin yapılması veya yaptırılması, test sonucunda raporlanan zafiyetlerin kapatılması için gerekli işlemlerin takibi ve en az yılda 1 (bir) kez olarak log analizlerinin yapılması faaliyetlerini gerçekleştirirler.

- Siber güvenlik politikaları belirler, bu politikaların uygulanıp uygulanmadığını izler ve denetler.
- Şirket personeline periyodik olarak bilgi güvenliği farkındalık eğitimi verilmesi için eğitimi verecek birime talepte bulunur. Ayrıca; Personelin ortak kullandığı alanlara siber güvenlik ile ilgili posterler asar.
- Şirket'in bilgi güvenliği farkındalığını belirleyecek anketler yapar.
- Siber güvenlik ile ilgili Şirket içi bülten hazırlar.
- Bilgi sistemleri denetimleri ve güvenlik testlerinin yapılması veya yaptırılması, çıkan sonuçların giderilmesini teminen koordinasyonun sağlanması ve tespit edilen zafiyetlerin ilgili birimlere iletilmesini sağlar.

- e) BGOM tarafından log kayıtları SIEM üzerinden günlük olarak izlenir ve herhangi bir Siber Olaya sebep verecek delillerin bulunup bulunmadığı takip edilir.
- f) BGOM SIEM üzerinde gerekli korelasyonları oluşturarak SOME'ye alarm üretilmesini sağlar. Oluşturulan korelasyonlar SOME Koordinatörü tarafından denetlenir.
- g) BGOM, otomatize tool taraması, sızma testi, güvenli yapılandırma denetimi faaliyetlerini gerçekleştirir. Güvenlik açıklıklarının giderilmesi yönünde takibini yapar.

6.2.1.2 Siber Olayın Bildirilmesi

PTT AŞ içerisinde bir KRİTİK seviyede Siber Olay tespit edildiği anda durum en kısa zamanda SOME koordinatörüne ve ilgili Birim Amirlerine iletilir. Bilgi e-posta (some@ptt.gov.tr), telefon üzerinden iletilir ve KRİTİK seviyede Siber Olay tespiti için yardım masası üzerinden kayıt açılır. Bilginin ilgili kişilere ulaştığı muhakkak teyit edilir. Acil önlem alınması gereken durumlarda aksiyon alındıktan sonra servis masası yazılımı üzerinden kayıt açılabilir.

6.2.1.3 Siber Olayın Değerlendirilmesi

6.2.1.3.1 SOME Koordinatörü olayın kendisine bildirilmesine müteakiben aynı gün içinde; olayı bildiren personel, olaydan Bilgi Teknolojileri Daire Başkanını ve Yardımcılarını haberdar eder. Konu ile ilgili Birim Müdürlerinin katılımı ile olayın değerlendirilmesi ve alınacak aksiyonların belirlenmesi için SOME Koordinasyon Toplantısı düzenler.

6.2.1.3.2 BT Bilgi Güvenliği Kurul Toplantısında olayın derinlemesine incelenmesi ve gerekli aksiyonların devreye alınması için ilgili uzman personellerden teşkil edilecek bir “Aksiyon ve Değerlendirme Ekibi” oluşturulur. Aksiyon Ekibi; SOME Personeli, doğrudan Bilişim Sistemlerine erişim sağlayarak kararlaştırılan aksiyonları yapacak birim personeli ve aksiyonlar için yöneticilerden gerekli izinleri alınır. Bu ekip BT Bilgi Güvenliği kurul toplantısında alınan aksiyon kararlarının yürütülmesini sağlar ve yapılan işlemlerle ilgili son durumu Bilgi Güvenliği Standardizasyon Müdürlüğüne ve Hukuk birimine iletir.

6.2.1.4 Siber Olaya Müdahale Süreci

6.2.1.4.1 Müdahale Sürecinin koordinasyonunu SOME Koordinatörü yürütür. Yapılan tüm iş ve işlemlerle ilgili bilgiler SOME Koordinatörüne anında iletilmesi ilgili süreç sorumluları (SOME'nin Operasyon Birimi) tarafından sağlanır.

6.2.1.4.2 Hukuki Süreç: Hukuk biriminin bilgilendirilmesi ve gerekli hukuki başvuruların yapılması SOME İletişim Birimi'nin görevidir. Hukuki bildirim yapılırken saldırganla ilgili IP bilgisi, Domain host bilgisi ve whois kaydı gibi tüm bilgilerin iletilmesi sağlanır. Hukuk Müşavirliği savcılık nezdinde girişimin en kısa zamanda sonuçlandırılmasını sağlar.

6.2.1.4.3 USOM İhbarı: Siber Olayla ilgili USOM merkezine (“usom.gov.tr” sayfası iletişim bölümünden) gerekli ihbarın yapılmasından ve sonucunun takip edilmesinden BGOM sorumludur.

6.2.1.4.4 UYUM Birimine Bildirim: BGOM Kritik seviyedeki olayları EBYS üzerinden bildirimini sağlar. Tüm Siber Olaylar ile ilgili raporlamalar BT Bilgi Güvenliği Kurulu Toplantısı'nda üst yönetime sunulur.

6.2.1.4.5 Basın Birimine Bildirim: Siber Olayla ilgili Basın Duyurusu yapıp yapılmayacağı Bilgi Teknolojileri Daire Başkanı tarafından yapılacak değerlendirme Tanıtım ve Medya Daire Başkanlığı tarafından yapılır.

6.2.1.4.6 Müşterilerin Bilgilendirilmesi: Siber Olaydan etkilenen veya etkilenme riski bulunan müşterilere Tanıtım ve Medya Daire Başkanlığı tarafından en uygun kanallarla doğrudan bilgilendirme yapılır.

6.2.1.4.7 Kanıtların Güvenliğinin Sağlanması: Bilişim altyapısında çalışan sistemlerin üzerinden (BTD-PR01 Log Yönetim Prosedüründe belirtilen, Logların adli makamlar tarafından yapılan yazılı bildirimine istinaden) ilgili işlem kayıtlarının toplanarak talep edildiği durumda güvenlik birimlerine teslim edilmesi SOME Birimi sorumluluğundadır.

6.2.1.4.8 Adli makamlar ve Rehberlik ve Teftiş Başkanlığı tarafından istenilen kanıtlar talep biriminin talebi üzerine gerçekleştirilir. Diğer kanıt talepleri ise talep biriminin bağlı olduğu Genel Müdür Yardımcısından olur alınması durumunda Bilgi Teknolojileri Daire Başkanlığınca değerlendirilerek talep gerçekleştirilir. Kanıtların iletilmesi için SFTP protokolü veya dosya.ptt.gov.tr adresi kullanılır.

6.2.1.4.9 Ağ kayıtları, sunucu kayıtları, veri tabanı kayıtları, güvenlik cihazları kayıtları ve uygulama kayıtlarının tutulmak üzere log sistemine alınması ve ihtiyaç duyulduğunda SOME'ye sunulması Bilgi Güvenliği Operasyon Müdürlüğü sorumluluğundadır.

6.2.1.4.10 Siber Olay ile ilgili maddi işlem kayıtlarının talep edilmesi durumunda söz konusu kanıtlar İşletme, Bilgi Teknolojileri ve Bilişim Daire Başkanlığı temin edilerek SOME aracılığıyla ilgili güvenlik birimlerine teslim edilir.

6.2.1.4.11 Siber Olay ile ilgili kamera kayıtları Yapı Daire Başkanlığınca sağlanır.

SOME, Siber Olay ile ilgili toplanan kanıtları birleştirerek Siber Olayın meydana geliş şeklini ortaya koymak için gerekli çalışmaları yapar.

6.2.1.4.12 Siber Olayın tekrar edilmesi ihtimaline karşın SIEM üzerinde gerekli uyarı mekanizmalarının kurulması, BGOM tarafından sağlanır. Bilgi Teknolojileri, İşletme ve Bilişim Daire Başkanlıkları tarafından da maddi işlem kayıtları üzerinde gerekli uyarı mekanizmaları oluşturularak SIEM'e eklemek üzere BGOM'a iletilir.

6.2.1.4.13 Ekibe SOME Koordinatörü başkanlık eder.

6.2.1.4.14 Çalışma aşamaları sırasında SOME Koordinatörü sürekli olarak bilgilendirilir.

6.2.1.4.15 Çalışmanın tamamlanması ile yapılan değerlendirmeler ve alınan aksiyonlarla ilgili 3 (üç) Aylık istatistiki veriler SOME Koordinatörü tarafından hazırlanır ve Bilgi Güvenliği Standardizasyon Müdürlüğü'ne sunulur. Üç aylık periyotta hazırlanan istatistiki veriler BT Bilgi Güvenliği Kurul toplantısında değerlendirilir. Varsa alınacak yeni aksiyonlar belirlenir.

6.2.2 Siber Olay Sonrasında SOME'lerin Görev ve Sorumlulukları

Şirkette bir Siber Olay gerçekleştikten ve Siber Olaya müdahale edildikten sonra SOME aşağıda belirtilen görevleri icra eder;

a) SOME, SOME Koordinatörü tarafından belirlenir ve BTD.FR42 Siber Olaylara Müdahale Ekibi Formu ile Bilgi Teknolojileri Daire Başkanının onayına sunulmaktadır.

SOME "Aksiyon ve Değerlendirme Ekibi"nin raporu doğrultusunda Siber Olaya neden olan teknik ya da yazılım iş mantığıyla ilgili açıklıkları belirler ve çıkarılan dersleri kayıt altına alır.

b) Siber Olayın tekrarlanması ihtimaline karşı gerekli uyarı mekanizmalarını belirler, Bilgi Teknolojileri ve Bilişim Daire Başkanlığı Müdürlükleri ile paylaşır. İstatiksel rapor Bilgi Güvenliği Operasyon Müdürlüğü tarafından BT Bilgi Güvenliği Kurul toplantısında sunulur. Sunulan rapor BT Bilgi Güvenliği Kurul toplantısında değerlendirilir. Siber Olay ile ilgili olarak gerçekleştirilebilecek düzenleyici faaliyetlere ilişkin önerileri Bilgi Teknolojileri ve Bilişim Daire Başkanlığı Müdürlükleri'ne iletir.

c) Yaşanan Siber Olayların türlerini, miktarlarını ve maliyetlerini değerlendirir.

7. ONAY

Bu prosedür Genel Müdür tarafından onaylanır.

8. YÜRÜRLÜK

Bu talimat yayımlandığı tarihte yürürlüğe girer.

9. YÜRÜTME

Bu talimatı Genel Müdür yürütür.

10. REFERANS DOKÜMANLAR

BTD.FR42-Siber Olaylara Müdahale Ekibi Formu

BTD.PR01-Log Yönetim Prosedürü

BTD.TB04-Güvenlik Zafiyet Takip Tablosu

BTD.TB07-Güvenlik Tarama Periyot Tablosu

EYS.FR24-Risk Bilgilendirme Formu

STD.004-TS EN ISO-IEC 27001 Bilgi Güvenliği Yönetim Sistemi Standardı